

Core Platform Framework

90 BZA 매뉴얼

BZA 도입 담당자 · 업무 관리자 · 권한/결재 운영자

문서 목적	조직·직원·사용자·권한·Data Scope·결재·위임·첨부·알림·감사 기능을 선택·설치·운영하고 고객 Domain 과 연결합니다.
Repository / Branch	freeangelsun/202412_01_CPF / master
기준 Source / 정보	Repository f6d7080c5a14b7dd7595093f9497470169e18d80 Product Source f0aa49f29cba3cfd6ae12b0ddd4e118d05fff16c 최상위 요구사항 cpf-docs/governance/CPF_FINAL_TARGET_REQUIREMENTS.md 문서 표준 cpf-docs/specification/CPF_DOCUMENTATION_STANDARD.md
문서 성격	완성 기준 사용자 문서. 제품이 완료된 상태에서 사용자가 설치·개발·운영·복구·검증 업무를 끝낼 수 있도록 정상 절차, 실패 판정, 복구, 확인 근거를 기술합니다.

읽는 방법 먼저 “빠른 찾기”에서 질문을 찾고, 상세 설명은 각 기능의 정보 절로 이동하십시오. 다른 매뉴얼은 같은 내용을 반복하지 않고 정보 절을 참조합니다.

빠른 찾기 - 질문에서 정보 절로

개발자가 묻는 질문	이 문서의 정보 위치	다른 문서 연결
BZA 가 필요한가?	§2 도입 판단	조직/권한/결재 공통 제품 필요 여부
어떻게 설치/기동?	§3 설치	DB/Secret/Port/Health
초기 관리자는?	§4 Bootstrap/인계	고정 비밀번호 문서화 금지
권한 계산은?	§6 Role/Permission/Data Scope	effective permission + simulation
결재/위임은?	§7	policy/snapshot/delegation
첨부/알림/감사는?	§8	지원 가능
실제 화면은?	§10 Route Reference	26 개 Route

완성 기준 이 문서는 제품 완료 상태에서 사용자가 수행할 최종 업무 계약을 기술합니다. 각 절은 선행조건 → 입력/설정 → 실행 → 정상 판정 → 실패/부분 실패 → 복구/대사 → Evidence 순서로 담으며, Source Trace 는 구현 위치를 제공합니다.

1. BZA 의 역할

BZA 는 고객 업무 관리에 반복되는 조직/직원/사용자/Role/Permission/Data Scope/결재/위임/감사/첨부/알림을 제공하는 선택 제품입니다. 고객 업무 원장을 BZA 가 대신 소유하는 구조가 아닙니다.

2. 도입 판단 - 언제 선택하고 언제 선택하지 않는가

상황	판단
여러 업무에서 조직/Role/Data Scope/결재를 공통 사용	BZA 선택 검토
단순 플랫폼 운영자만 필요	ADM 으로 충분한지 검토
고객 업무별 권한 모델이 완전히 독립	BZA 를 억지로 중앙 원장으로 만들지 말고 Integration 계약만 사용
조직 기준일/검직/위임/감사가 중요	BZA 적합
외부 API 라우팅/보안 목적	BZA 가 아니라 Gateway 정본

3. 설치·기동

항목	Source 계약 기준
Server port	BZA_SERVER_PORT 기본 8091
DB	CPF_BZA_DB_ENABLED 기본 false; URL/JNDI 선택
JWT Secret	CPF_BZA_JWT_SECRET - Secret 주입
Access TTL	600s
Refresh TTL	7200s
Health	health/info/metrics/prometheus 노출 설정

1. BZA 사용 여부와 DB/인증 Topology 를 결정한다.
2. DB Vendor Pack/Schema 를 05/DB 표준에 따라 설치한다.
3. JWT Secret 과 DB credential 을 Secret 경로로 주입한다.
4. BZA 를 기동하고 health/readiness 를 확인한다.
5. 초기 관리자/Role/Permission 인계 절차를 수행한다.
6. 조직/직원 기준정보를 먼저 구성한 뒤 업무 Role/Data Scope/결재 정책을 구성한다.

4. 초기 관리자·Bootstrap·보안 인계

- 초기 관리자 생성 기능은 고정 공용 비밀번호를 제품/문서에 두는 방식이 아니어야 합니다. 실제 Bootstrap 계약/Seed/Environment 를 설치 Evidence 에서 확인합니다.

- 초기 credential 은 첫 로그인/인계 후 변경 또는 폐기하고, bootstrap 경로를 운영 상시 경로로 남기지 않습니다.
- BZA 화면/로그/다운로드에서 비밀번호·Refresh token·Secret 원문을 재표시하지 않습니다.

5. 조직·직원·사용자 수명주기

객체	핵심 Field/개념	경계
Organization	계층/기준일/활성기간	삭제보다 유효기간/상태 전이 우선
Employee	개인/연락/소속	Masking/Data Scope
Position/JobTitle	직급/직책 기준	코드 중복/유효기간
Assignment	검직/파견/대행	기간 중첩/우선순위
Responsibility	조직장/승인 Owner	기준일 해석
User	인증 주체	직원과 인증 계정의 수명주기 분리

6. Role·Permission·Data Scope

- Menu/Action/API/Field/Data Scope 권한을 분리해 정의합니다.
- User 에 직접 권한을 난립시키기보다 Role 과 유효기간을 사용합니다.
- 실효 권한은 현재 조직/검직/Role/Data Scope 기준일을 함께 평가합니다.
- Permission Tools 에서 Role 비교/effective permission/simulation 으로 변경 전 영향을 확인합니다.
- 서버가 최종 판정하며 Frontend 숨김은 보안 경계가 아닙니다.

7. 결재·위임·대결

기능	정상 흐름	오류/경계
Policy	Versioned policy + 참여자 규칙	정책 변경은 진행 중 요청 snapshot 을 임의 변경하지 않음
Submission	idempotent submit	응답 유실 시 submission 조회
Decision	승인/반려 등 참여자 결정	SoD/권한/중복 결정 거부
Delegation	유효기간 위임/대결	기간 중첩/만료/자기위임 검증
Simulation	조직/Role/위임 사전 해석	Simulation 은 실제 승인/결정 권한을 부여하지 않음

8. Attachment·Notification·Session·Audit·Export

기능	운영 포인트
Attachment	업로드→보안검사→다운로드 권한; 경로/파일명 traversal 차단
Notification	업무 완료와 전달 성공을 분리, Retry/DLQ 확인
Session	Refresh session revoke/expiry, credential 원문 저장 금지
Audit	변경 actor/reason/reference/before/after; Masking
Export/Download	정책/권한/대량 처리/다운로드 감사

9. 고객 Domain 연계와 확장

- BZA 가 고객 업무 원장 Table 을 직접 수정하지 않습니다. 고객 Domain Public API/Integration Contract 를 사용합니다.
- 조직/권한/결재 결과를 업무 Command 에 전달할 때 기준일, effective permission, approval reference, actor 를 명시합니다.
- BZA 내부 구현을 복제한 EDU 가 아니라 실제 외부 Consumer 계약 예제를 사용합니다.

10. 실제 BZA Route Reference

Route	Path	Menu	업무
dashboard	/	DASHBOARD	업무 운영 현황
organizations	/organizations	ORGANIZATION	조직 계층
employees	/employees	EMPLOYEE	직원 Profile
positions	/positions	EMPLOYEE	직급 기준정보
jobTitles	/jobTitles	EMPLOYEE	직책 기준정보
assignments	/assignments	EMPLOYEE	다중 소속·겸직·파견·대행
organizationResponsibilities	/organizationResponsibilities	ORGANIZATION	조직장·대행·승인 Owner
users	/users	AUTHORIZATION	BZA 인증 사용자
roles	/roles	AUTHORIZATION	업무 역할
userRoles	/userRoles	AUTHORIZATION	다중 Role 유효기간
menus	/menus	AUTHORIZATION	화면 메뉴 Registry
permissions	/permissions	AUTHORIZATION	화면·행위·API·Data Scope 권한
permissionTools	/permissionTools	AUTHORIZATION	Role 비교와 권한 Simulation
approvalInbox	/approvalInbox	APPROVAL	결재 처리 Inbox
approvalSubmissions	/approvalSubmissions	APPROVAL	정책 기반 먹등 상신
approvalPolicies	/approvalPolicies	APPROVAL	Versioned Policy/ALL·ANY·N_OF_M
approvalSimulation	/approvalSimulation	APPROVAL	조직/Role/위임 사전 해석
approvalDelegations	/approvalDelegations	APPROVAL	유효기간 위임·대결
sessions	/sessions	AUTHORIZATION	Refresh session 관리
audits	/audits	AUDIT	업무 감사
notifications	/notifications	SETTING	업무 알림
attachments	/attachments	ATTACHMENT	첨부 업로드·검증
savedSearches	/savedSearches	SETTING	사용자 검색 조건
settings	/settings	SETTING	BZA 업무 설정
downloads	/downloads	SETTING	다운로드 정책
downloadAudits	/downloadAudits	AUDIT	다운로드 감사

11. Route 유형별 운영 규칙

유형	대표 Route	운영 규칙
기준정보	organizations/employees/positions/jobTitles	검색→상세→version 확인→변경→감사
권한	users/roles/userRoles/menus/permissions/permissionTools	영향 Simulation 후 적용, 서버 effective permission 확인
결재	approval*	정책 version/snapshot/participant/delegation/응답 유실 대사
지원	sessions/audits/notifications/attachments/downloads	보안/Masking/전달/감사 기준

12. Backup·Restore·Upgrade·Rollback

- BZA DB 는 조직/권한/결재 원장이므로 Backup/Restore 시점과 업무 Domain 의 참조 일관성을 함께 검토합니다.
- Migration 은 중앙 DB Vendor Lifecycle 을 사용하고 verify 결과를 남깁니다.
- Application rollback 만으로 이미 적용된 DB migration/결재 변경이 되돌아간다고 가정하지 않습니다.

13. 완료 판정과 운영 제한

- 26 개 Route 는 조직·인사·권한·결재·지원 업무의 Owner Route 로 유지하며, 각 Route 의 Permission/Data Scope/입력/상태/오류/감사를 E2E Acceptance 로 확인합니다.
- BZA DB/Secret/Token TTL/Session/Permission 정책은 설치 Profile 과 운영 보안 정책에 맞게 주입하고, 로그인·Refresh·Revoke·권한 변경·감사 시나리오에서 확인합니다.

관련 정보 문서

플랫폼 설치/DB/Secret → [05 플랫폼운영매뉴얼.pdf](#) / 설치/Config

권한/보안 표준 → [../deliverables/기술표준서.pdf](#) / 보안 표준

DB lifecycle → [../deliverables/데이터베이스표준서.pdf](#) / Migration/Backup

Source Trace / 구현 근거

구분	실제 경로·계약	완료 기준
BZA config	cpf-biz-admin/src/main/resources/application.yml	DB/Security/Token/Port/Config 계약 일치
BZA Route Registry	cpf-biz-admin/frontend/src/app/routes.ts	26 개 Route/Menu/Operation Registry 일치
Browser E2E	실브라우저	조직·권한·결재·첨부·감사 Browser/E2E 시나리오 통과

14. 26 개 BZA Route 업무 Reference

Route	업무	검색/입력	조치	경계
organizations	조직 계층	코드/명/상위/기간	저장	기간 중첩/순환
employees	직원 Profile	사번/성명/소속/상태	저장	PII masking
positions	직급	코드/명/순서	저장	중복/유효기간
jobTitles	직책	코드/명	저장	중복/유효기간
assignments	발령·겸직	직원/조직/기간/유형	저장	기간 중첩
organizationResponsibilities	조직 책임	조직/책임자/기간	저장	approval owner 영향
users	인증 사용자	ID/employee/status	저장	activation/session
roles	업무 Role	code/name/status	저장	permission impact
userRoles	사용자 Role	user/role/기간	저장	effective date
menus	메뉴 Registry	menu/path/status	저장/삭제	impact
permissions	권한	type/resource/action/scope	저장	server enforcement
permissionTools	권한 분석	user/role/date	simulation	실제 권한 변경 아님
approvalInbox	결재 Inbox	actor/status/date	decision	SoD/version
approvalSubmissions	결재 상신	policy/target/reason/key	submit/cancel/resubmit/withdraw	idempotency/response loss
approvalPolicies	결재 정책	version/step/rule	save	snapshot immutability
approvalSimulation	경로 Simulation	policy/actor/context	simulate	비실행
approvalDelegations	위임	from/to/기간	save	중첩/만료
sessions	세션	device/time/state	revoke	refresh token 원문 금지
audits	업무 감사	actor/action/target/time	verify	immutable/masking
notifications	알림	recipient/status/channel	read/create	delivery 분리
attachments	첨부	file/hash/status	upload/download/recheck	scan/permission

Route	업무	검색/입력	조치	경계
savedSearches	저장검색	user/name/filter	save/disable	PII filter
settings	업무 설정	key/value	조회/관리	secret 분리
downloads	다운로드 정책	resource/limit/mask	조회	policy
downloadAudits	다운로드 감사	actor/file/time	조회	대량/PII
dashboard	업무 현황	summary	조회	stale/partial

15. Effective Permission 계산 질문

1. 기준일과 사용자를 확정합니다.
2. 활성 User/Employee/Assignment/조직 책임을 해석합니다.
3. 유효한 UserRole 과 Role 상태를 확인합니다.
4. Role 의 Menu/Action/API/Data Scope 를 합성합니다.
5. 위임/대결이 권한 또는 결재 참여자에 미치는 범위를 별도로 계산합니다.
6. Permission Simulation 결과와 실제 서버 API 의 effective permission 을 비교합니다.

16. 결재 응답 유실/중복 처리

상황	판정	행동
상신 응답 유실	submission 생성 여부 불명	idempotencyKey 로 조회
같은 key 같은 hash	동일 요청	기존 결과 반환/조회
같은 key 다른 hash	conflict	거부
승인 결정 응답 유실	participant state 불명	request detail/history 조회
정책 변경 중 진행 요청	snapshot 기준	기존 snapshot 유지
위임 만료	더 이상 적용 안 됨	새 actor 기준 재평가

17. BZA 보안/감사 Checklist

축	확인
PII	Employee 연락처/식별 정보 masking
Credential	password/token/JWT secret 원문 미노출
Data Scope	조직/업무 범위 server check
Download	정책/마스킹/감사
Approval	requester/approver SoD
Session	revoke/expiry
Audit	변경 전후/actor/reason/reference
Attachment	path/content type/scan/download auth

18. 조직/인사 기준일 처리 시나리오

시나리오	해석	주의
오늘 조직 조회	current effective row	미래 발령은 아직 적용 안 됨
미래 발령 등록	validFrom 미래	현재 permission 바로 변경 금지
겸직	여러 Assignment 동시 유효	Data Scope 합성/우선순위 정의
파견 종료	validTo 만료	Role/Responsibility 후속 영향
조직장 대행	Responsibility 기간	결재 Owner 해석에 반영

시나리오	해석	주의
소급 정정	과거 effective date	Audit/결재 snapshot/다운로드 영향 검토

19. Permission 변경 전 영향 분석

1. 변경하려는 Role/Permission 과 기준일을 선택합니다.
2. Permission Tools 에서 현재 effective permission 과 변경 후 simulation 을 비교합니다.
3. Menu/Action/API/Data Scope 각각의 추가/삭제를 분리합니다.
4. 사용자/조직 범위가 넓어지는 변경은 Reason/Approval/Audit 정책을 적용합니다.
5. 적용 후 실제 서버 effective-permission API 결과를 다시 확인합니다.
6. 예상하지 못한 접근 증가가 있으면 기존 version/설정으로 되돌리고 Audit 을 남깁니다.

20. 결재 전체 Lifecycle

단계	상태/증거	오류/복구
Policy 선택	policyId/version	정책 없음/비활성
Simulation	예상 participant/경로	조직/위임 입력 오류
Submit	submission id/idempotency	response loss→lookup
Snapshot	participant/policy snapshot	정책 변경 영향 차단
Decision	participant result/time	중복/권한/만료 거부
Complete	approved/rejected/cancelled	N_OF_M/ALL/ANY 판정
Execute	업무 command reference	응답 유실→operation reconcile
Audit	history/hash/actor	delivery 실패는 별도

21. 첨부파일 수명주기

1. 파일명/크기/Content-Type/권한을 검증합니다.
2. 임시 업로드 영역에 저장하고 checksum 을 계산합니다.
3. 보안 검사/정책을 수행합니다.
4. 통과한 파일만 업무 Attachment 상태로 공개합니다.
5. 다운로드 시 현재 사용자 Permission/Data Scope 를 다시 확인합니다.
6. Recheck/격리/삭제/보존 기간 변경은 Audit 을 남깁니다.

22. Download/Export 통제

통제	필수
권한	일반 조회와 별도 download/export action
Data Scope	현재 기준일/조직 범위 재적용
Masking	화면과 동일하거나 더 엄격한 정책
Volume	온라인 메모리 대량 생성 금지, Job/streaming 검토
Audit	actor/filter/row count/file hash/time
Retention	artifact 만료/삭제
Response loss	생성 job/result 를 조회, 중복 생성 주의

23. BZA 장애 Runbook

장애	영향	확인	복구
JWT Secret 오류	로그인/API 인증 실패	startup/auth log/secret ref	secret 교정/rotate

장애	영향	확인	복구
DB down	조직/권한/결재 불가	health/connection	DB 복구 + consistency
Permission 오설정	과다/과소 권한	simulation/effective API/audit	role/permission version 수정
Approval stuck	업무 지연	participant/delegation/expiry	정책/위임 교정, 재대사
Attachment scan 실패	다운로드 제한	security status	격리/recheck
Notification provider down	알림 지연	delivery attempts	retry/DLQ; 업무 결과와 분리

24. BZA 도입·운영 완료 판정 Gate

영역	완료 조건
설치	DB/Secret/Port/Health 와 초기 관리자/보안 인계 완료
조직/인사	기준일·검직·책임·발령의 유효기간과 조회 결과가 일치
권한	Role/Permission/Data Scope/effective permission/Simulation 결과가 서버 판정과 일치
결재	Policy version/snapshot/participant/delegation/SoD/idempotency/UNKNOWN 대사가 담힘
지원	Attachment/Notification/Session/Audit/Download 의 보안·감사·복구 절차 수행 가능
연계	고객 Domain 을 Public 계약으로 호출하고 BZA 가 업무 원장 DB 를 직접 갱신하지 않음
복구/인수	Backup/Restore/Upgrade/Rollback + Route/권한/감사 Evidence 가 인계됨

25. BZA 인수 Evidence Record

영역	Evidence
Install/Security	DB/port/health/JWT secret/session TTL/initial admin handover
Organization	effective date/org/employee/assignment/responsibility sample
Permission	role/permission/data scope/effective permission/simulation result
Approval	policy version/snapshot/participant/delegation/SoD/idempotency/unknown result
Support	attachment scan/notification/session/audit/download/export evidence
Integration	customer domain public contract + reference ids + audit
Recovery	backup/restore/upgrade/rollback + route/permission/audit browser result